

CYBERSECURITY RISK ASSESSMENT

Methodology Report

CASE STUDY

EXECUTIVE SUMMARY

This document defines the risk assessment methodology used in the accompanying **GRC Risk Register** for a simulated SaaS environment. It establishes a structured and repeatable approach for identifying, assessing, and treating cybersecurity and operational risks.

The methodology is based on a qualitative-to-quantitative hybrid model where risk is first evaluated using a **Likelihood × Impact** scoring system. This score is then mapped to an Inherent Risk Level using a defined risk matrix. Existing security controls are assessed based on their effectiveness in reducing either likelihood, impact, or both, resulting in a final Residual Risk Level.

Risk treatment decisions (Accept, Mitigate, Transfer, Avoid) are derived based on residual risk levels in relation to an assumed organizational risk appetite. This ensures consistency in decision-making and alignment with governance principles.

The framework is designed to be simple, auditable, and aligned with common industry practices such as ISO 27001-style risk management, ensuring traceability between risk identification, control implementation, and risk acceptance decisions.

1. INTRODUCTION

1.1 PURPOSE

The purpose of this document is to define a structured and repeatable methodology for identifying, assessing, and treating cybersecurity and operational risks within a simulated SaaS environment. It explains how risk scores are calculated, how controls influence risk reduction, and how final risk treatment decisions are derived to ensure consistency and traceability across the risk register.

1.2 SCOPE

This methodology applies to all risks identified within the SaaS environment, including cloud infrastructure, application systems, data storage, and user access controls. It covers risk assessment using Likelihood × Impact scoring, evaluation of existing control effectiveness, calculation of residual risk, and determination of appropriate risk treatment actions (Accept, Mitigate, Transfer, Avoid).

2. RISK SCORING METHODOLOGY

The risk scoring methodology provides a consistent approach for **evaluating inherent risk** by assessing the likelihood of an event occurring and the impact it would have on business operations. This ensures that all risks in the register are assessed using a standardized and repeatable model.

2.1 LIKELIHOOD SCALE

Likelihood represents the probability of a risk event occurring.

Level	Score	Description
Low	1	Rare or unlikely to occur
Medium	2	Possible occurrence under certain conditions
High	3	Likely or frequently occurring

2.2 IMPACT SCALE

Impact represents the severity of consequences if the risk materializes.

Level	Score	Description
Low	1	Minor operational disruption, limited effect
Medium	2	Noticeable business impact, manageable disruption
High	3	Severe impact on operations, data, or reputation

2.3 INHERENT RISK CALCULATION

Inherent risk is calculated using a simple scoring formula:

$$\text{Inherent Risk Score} = \text{Likelihood} \times \text{Impact}$$

This produces a score between **1 and 9**, representing the severity of the risk before applying any controls.

2.4 INHERENT RISK RATING MATRIX

The calculated score is mapped to a risk level using the following scale:

Score	Risk Level
1-2	Low
3-4	Medium
6	High
9	Critical

2.5 INTERPRETATION RULE

- Higher likelihood and higher impact result in significantly higher inherent risk exposure.
- This model ensures consistent prioritization of risks based on severity rather than subjective judgment.
- All risks are assessed uniformly to ensure comparability across the risk register.

3. CONTROL EFFECTIVENESS MODEL

The Control Effectiveness Model defines how existing security controls reduce inherent risk by lowering either the likelihood of a risk event occurring, its potential impact, or both. This model is used to assess how effective current safeguards are in mitigating risk exposure.

3.1 CONTROL EFFECTIVENESS LEVELS

Each control is evaluated based on its overall ability to reduce risk exposure.

Level	Description
Weak	Provides minimal risk reduction; limited or inconsistent effectiveness
Moderate	Provides partial risk reduction; reduces either likelihood or impact to some extent
Strong	Provides significant risk reduction; effectively reduces likelihood and/or impact

3.2 HOW CONTROLS REDUCE RISK

Controls are classified based on *how they influence risk*:

3.2.1 PREVENTIVE CONTROLS (REDUCE LIKELIHOOD)

These controls aim to stop the risk from occurring. Examples:

- Multi-Factor Authentication (MFA)
- Access controls (RBAC)
- Email filtering

3.2.2 DETECTIVE CONTROLS (IDENTIFY INCIDENTS EARLY)

These controls detect risk events after or during occurrence. Examples:

- Security monitoring
- Log analysis
- Intrusion detection systems

3.2.3 CORRECTIVE/RECOVERY CONTROLS (REDUCE IMPACT)

These controls reduce damage after a risk occurs. Examples:

- Backups
- Disaster recovery plans
- Incident response procedures

3.3 CONTROL IMPACT ON RISK

Control effectiveness determines how much the inherent risk is reduced to arrive at residual risk:

- **Strong controls** → significantly reduce risk (often lowering risk level by 1–2 tiers)
- **Moderate controls** → partially reduce risk (usually 1 tier reduction)
- **Weak controls** → minimal or no meaningful reduction

3.4 INTERPRETATION RULE

- Control effectiveness is not binary; it is evaluated based on coverage, maturity, and reliability.
- A combination of controls may collectively increase effectiveness level.
- Even strong controls do not eliminate risk entirely, especially for evolving threats.

4. RESIDUAL RISK METHODOLOGY

Residual risk represents the level of risk remaining after existing controls have been applied. It reflects the organization's actual exposure in the current control environment and is used to determine whether additional treatment actions are required.

4.1 RESIDUAL RISK EVALUATION

Residual risk is derived by evaluating:

1. The inherent risk level
2. The effectiveness of existing controls
3. The extent to which controls reduce likelihood, impact, or both

The residual risk rating is then adjusted based on the assessed control effectiveness.

RESIDUAL RISK ADJUSTMENT LOGIC

Inherent Risk	Control Effectiveness	Typical Residual Risk
Critical	Strong	High
Critical	Moderate	High
High	Strong	Medium
High	Moderate	Medium
Medium	Strong	Low
Medium	Moderate	Medium
Low	Strong	Low

4.2 RESIDUAL RISK GUIDANCE

- Residual risk reflects the *remaining exposure* after safeguards are considered.
- Strong controls significantly reduce risk exposure but do not guarantee full risk elimination.
- Risks with higher residual levels typically require additional mitigation or monitoring activities.

4.3 RESIDUAL RISK ASSESSMENT PRINCIPLES

- Preventive controls primarily reduce likelihood.
- Corrective and recovery controls primarily reduce impact.
- Multiple layered controls may collectively reduce residual risk more effectively than single control.
- Residual risk assessments are qualitative and may involve professional judgment where appropriate.

5. RISK TREATMENT FRAMEWORK

The Risk Treatment Framework defines the actions taken to manage residual risk after assessment. Treatment decisions are based on residual risk severity, control effectiveness, business impact, and the organization's assumed risk appetite.

5.1 RISK TREATMENT OPTIONS

5.1.1 ACCEPT

The organization acknowledges the residual risk and decides that no additional controls are required because the remaining exposure is within acceptable tolerance levels. **Typically used when:**

- Residual risk is Low
- Existing controls are considered sufficient
- Additional mitigation is not cost-effective

5.1.2 MITIGATE

Additional controls or security measures are implemented to further reduce the likelihood or impact of the risk. **Typically used when:**

Residual risk exceeds acceptable tolerance

- Additional safeguards can reasonably reduce exposure
- Continuous improvement is required

5.1.3 TRANSFER

A portion of the risk impact or operational responsibility is shifted to a third party. **Typically used when:**

- Specialized external protection or services are available
- Financial or operational exposure can be contractually shared
- Third-party providers can manage specific threat areas more effectively

5.1.4 AVOID

The activity, system, or process causing the risk is discontinued or removed entirely. **Typically used when:**

- Risk exposure is unacceptable
- Effective mitigation is not feasible
- Business value does not justify the risk

5.2 TREATMENT DECISION PRINCIPLES

- Residual risk is the primary factor influencing treatment decisions.
- Risks with Low residual exposure are commonly accepted.
- Medium or High residual risks generally require mitigation or partial transfer strategies.
- Treatment decisions should balance security requirements, operational impact, and business objectives.

5.3 ASSESSMENT GUIDANCE

Risk treatment does not eliminate risk entirely; it defines how the organization chooses to manage the remaining exposure in alignment with governance and operational priorities.

6. ASSESSMENT ASSUMPTIONS

The following assumptions were established to ensure consistency and practicality throughout the risk assessment process.

6.1 SAAS ENVIRONMENT CONTEXT

This assessment assumes a mid-sized SaaS environment utilizing cloud-hosted infrastructure, centralized user authentication, internet-facing applications, and storage of customer-related data. The environment includes common enterprise security controls such as MFA, RBAC, encryption, monitoring, and backup mechanisms.

6.2 RISK APPETITE ASSUMPTION

The organization is assumed to maintain a **Low-Medium risk appetite** for cybersecurity and operational risks affecting confidentiality, integrity, availability, and business continuity. As a result:

- High residual risks generally require mitigation
- Low residual risks may be accepted if existing controls are considered sufficient
- Critical risks are assumed to require immediate treatment

6.3 CONTROL ASSESSMENT ASSUMPTION

Control effectiveness ratings are based on the assumed presence, coverage, and operational reliability of implemented controls. The assessment assumes controls are functioning as intended unless otherwise specified.

7. ASSESSMENT LIMITATIONS

This assessment uses a simplified qualitative methodology intended for educational and portfolio demonstration purposes. While aligned with common GRC principles, certain limitations apply.

7.1 QUALITATIVE SCORING LIMITATION

Risk ratings are derived using qualitative scoring (Low, Medium, High) converted into a simplified numerical model. Actual enterprise risk programs may use more granular scoring scales, weighted calculations, or financial impact analysis.

7.2 CONTROL ASSESSMENT SUBJECTIVITY

Control effectiveness evaluations involve professional judgment and may vary depending on implementation maturity, operational coverage, and organizational context.

7.3 DYNAMIC THREAT LANDSCAPE

Cybersecurity risks continuously evolve over time. The risk levels and treatment decisions documented in this assessment represent a point-in-time evaluation and may require periodic reassessment.

7.4 SIMPLIFIED ENVIRONMENT SCOPE

The assessment focuses on common SaaS cybersecurity risks and does not include advanced enterprise considerations such as regulatory obligations, third-party supply chain dependencies, or quantitative financial risk modeling.